

DATA PROCESSING AGREEMENT

Incorporating EU Standard Contractual Clauses (Module 2)

DRAFT FOR LEGAL REVIEW — NOT YET APPROVED, NOT YET IN EFFECT

Data Exporter (Controller)	[Referring practitioner / practice name] — to be completed per practitioner at execution
Data Importer (Processor)	Applied Neurosciences Pty Ltd, trading as QEEG.com.au (ABN: [insert]), Victoria, Australia
Purpose	Governs the processing of personal data submitted to QEEG.com.au by practitioners located in the European Union or United Kingdom, in connection with the AI-generated QEEG/TOVA/symptom-checklist correlation report service
Status	First draft — built from the platform's actual architecture (Developer Specification v2.3) and the documented practice of comparable platforms (NovoPsych, Pearson/Q-Global), neither of which builds EU-region infrastructure for this purpose — both rely on a Data Processing Agreement incorporating Standard Contractual Clauses instead. This draft follows the same pattern.
Governing SCC instrument	Commission Implementing Decision (EU) 2021/914 of 4 June 2021, Module Two (Transfer Controller to Processor) — confirmed as the current, correct instrument at time of drafting; a lawyer should re-confirm this has not been superseded before execution
Prepared	As a starting point for Applied Neurosciences Pty Ltd's legal advisors — not a substitute for their review, and not itself legal advice

1. How to Use This Draft

This document is a starting point, built to give Applied Neurosciences Pty Ltd's legal advisors something concrete to work from rather than a blank page — it is not a finished agreement, and nothing in it should be treated as binding or as legal advice until reviewed and finalised by a qualified lawyer.

⚠️ NEEDS LAWYER INPUT — Read this whole document with a lawyer before anything else, not just the flagged sections.

The individual flags throughout mark specific points needing a lawyer's judgement, but the structure and drafting of the whole document — every clause, not only the flagged ones — needs professional review before this is used with a real practitioner.

1.1 Why this document takes this shape

The core problem it solves: Applied Neurosciences Pty Ltd hosts QEEG.com.au on a single server in Sydney, Australia — a country the European Commission has not recognised as providing an adequate level of data protection. Under GDPR, personal data cannot lawfully be sent there without an additional legal safeguard, regardless of how little data is actually transmitted or how it's technically protected.

Two comparable platforms were checked directly to see how they handle the same problem, rather than assuming a novel solution was needed: NovoPsych (Australian-hosted, AWS infrastructure) states it relies on Standard Contractual Clauses for data leaving the EEA, and treats full EU-region hosting as an optional Enterprise-tier accommodation rather than a baseline requirement. Pearson (Q-Global) primarily hosts in Canada — a jurisdiction the EU does recognise as adequate — with supplementary EU hosting and Standard Contractual Clauses layered in for specific flows. Neither treats building EU-region infrastructure as the default answer; both use a Data Processing Agreement incorporating Standard Contractual Clauses as the primary mechanism. This draft follows that same, more proportionate pattern rather than assuming Applied Neurosciences Pty Ltd needs to replicate a multinational's infrastructure footprint.

⚠️ NEEDS LAWYER INPUT — Digital Pacific hosting was already a deliberate, considered decision for this project (chosen for Australian Privacy Act / Health Records Act alignment) — confirm this DPA approach is compatible with keeping that decision, not a reason to revisit it.

The developer specification's Section 2.4 already reasoned through this trade-off at a product level; this document assumes that reasoning stands and builds the legal mechanism around it, rather than re-opening the hosting decision.

1.2 Scope of This Agreement — Confirmed Approach

Confirmed: every practitioner reads and agrees to this Agreement at account creation, regardless of jurisdiction — not only practitioners in the European Union or United Kingdom on request, as an earlier draft of this project's Terms of Service had specified. This is simpler to operate than maintaining a jurisdiction-specific signup flow, but it does mean an Australian practitioner is asked to accept the same document as an EU practitioner, including clauses (Clause 6, Annex IV) that describe a legal mechanism that does not actually apply to them.

How this draft resolves that, subject to the lawyer's agreement with the approach:

Clauses 1–5 and 7–12 state Applied Neurosciences Pty Ltd's general data-handling commitments and apply to every practitioner as a description of how the Service actually works, regardless of where they practise.

Clause 6 (International Transfers) and Annex IV (the Standard Contractual Clauses) exist specifically to satisfy a legal requirement that arises only when data is transferred from the EU/UK to a non-adequate third country. For a practitioner practising outside the EU/UK, these sections describe a mechanism that is not actually operative for their own use of the Service — included in the single document every practitioner signs only so one Agreement serves everyone, rather than requiring several jurisdiction-specific versions.

This scoping approach itself needs the lawyer's sign-off — it is a reasonable-seeming resolution to “everyone signs one document, but not everyone needs the SCC content,” not a settled legal position. An alternative worth considering: a short jurisdiction-detection step at signup that shows only the clauses actually relevant to that practitioner, rather than one document with an internal scoping note. That's a product decision as much as a legal one.

2. Definitions

“Agreement” means this Data Processing Agreement, including its Annexes and the attached Standard Contractual Clauses.

“Applicable Data Protection Law” means the GDPR (Regulation (EU) 2016/679); the UK GDPR and the UK Data Protection Act 2018, to the extent applicable; and, for the avoidance of doubt, the Privacy Act 1988 (Cth) as it applies to the Processor's own handling of personal information in Australia.

“Controller” / “Data Exporter” means the referring practitioner who submits personal data to the Services, as defined under Applicable Data Protection Law.

“Processor” / “Data Importer” means Applied Neurosciences Pty Ltd, trading as QEEG.com.au.

“Data Subject” means the identified or identifiable natural person to whom the personal data submitted to the Services relates (i.e. the Controller's client/patient).

“Personal Data” means has the meaning given in the GDPR, and for the purposes of this Agreement means the data described in Annex I.

“Services” means the QEEG.com.au platform's QEEG/TOVA/symptom-checklist correlation report generation service, as described in the Terms of Service.

“Standard Contractual Clauses” or “SCCs” means the standard contractual clauses for the transfer of personal data to third countries set out in the Annex to Commission Implementing Decision (EU) 2021/914 of 4 June 2021, Module Two (Transfer Controller to Processor), attached to this Agreement as Annex IV.

“Sub-processor” means any third party engaged by the Processor to process Personal Data in connection with the Services, as listed in Annex III.

3. Subject Matter, Duration, Nature and Purpose of Processing

The subject matter, duration, nature, purpose, and categories of Personal Data and Data Subjects are set out in Annex I. In summary:

1. Subject matter: generating an AI-produced literature-correlation report from QEEG, TOVA, and symptom checklist data.
2. Duration: for each individual submission, processing occurs only for the period between upload and the Controller's download of the completed report — typically minutes to hours, not an ongoing retention period. This Agreement itself remains in effect for as long as the Controller holds an active QEEG.com.au account.
3. Nature: automated correlation of de-identified clinical data against published literature; no human review of individual submissions.
4. Purpose: to provide the Controller with research-literature correlations for their own clinical consideration — never a diagnosis, never a treatment recommendation.

⚠️ NEEDS LAWYER INPUT — Confirm whether QEEG/symptom data, even de-identified, should be treated as GDPR Article 9 'special category' (health) data for the purposes of this Agreement.

The platform's own architecture strips every field capable of identifying the individual (name, date of birth, every date field) before anything leaves the practitioner's browser — see Annex I and Annex II. Whether the residual age-and-gender-plus-clinical-findings dataset still constitutes identifiable 'health data' under GDPR Article 9 (given the Controller retains a case-reference-to-patient mapping the Processor never sees) is a genuine legal question, not a design one, and should be resolved before this Agreement is finalised — it affects what legal basis and safeguards are required.

4. Processor Obligations

The Processor shall:

5. process Personal Data only on the Controller's documented instructions, including with regard to international transfers, unless required to do otherwise by Australian law, in which case the Processor shall inform the Controller of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest;
6. ensure that persons authorised to process Personal Data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;
7. implement the technical and organisational security measures set out in Annex II, and take any further steps reasonably necessary to protect Personal Data against unauthorised or unlawful processing and against accidental loss, destruction, or damage;
8. not engage a Sub-processor without the Controller's general written authorisation (given by entering into this Agreement, on the terms of Clause 5 below), and remain fully liable to the Controller for the performance of each Sub-processor's obligations;
9. assist the Controller, insofar as possible given the nature of the processing and the information available to the Processor, in responding to requests from Data Subjects exercising their rights under Applicable Data Protection Law — noting the practical point in Clause 7 below;
10. assist the Controller in ensuring compliance with its obligations under GDPR Articles 32 to 36 (security of processing, breach notification, data protection impact assessments, and prior consultation), taking into account the nature of processing and the information available to the Processor;
11. at the Controller's choice, delete or return all Personal Data after the end of the provision of the relevant Services, except to the extent Australian or European Union law requires storage of the Personal Data — noting Clause 4.1 below, which describes how this is already substantially satisfied by the platform's existing architecture;
12. make available to the Controller all information necessary to demonstrate compliance with the obligations in this Clause 4 and the SCCs, and allow for and contribute to audits, including inspections, conducted by the Controller or an auditor mandated by the Controller, subject to reasonable notice and confidentiality protections for other customers' data.

4.1 A structural point worth the Controller's and the lawyer's attention

The “delete or return data” obligation above is, for this Service specifically, substantially pre-satisfied by design rather than dependent on a manual process at contract end: every individual submission's de-identified data is automatically and permanently deleted from the Processor's infrastructure the moment the Controller downloads the completed report (Annex II, Clause 3), and reports never downloaded are purged on a backstop schedule. There is no standing repository of Controller data to “return” at the end of the engagement in the way this clause typically anticipates — by the time any such request would be made, the relevant data has ordinarily already been deleted as a matter of routine operation, not as a response to the request.

5. Sub-processors

The Controller provides general written authorisation for the Processor to engage the Sub-processors listed in Annex III. The Processor shall notify the Controller of any intended addition or replacement of a Sub-processor at least 30 days in advance, giving the Controller the opportunity to object on reasonable grounds relating to the protection of Personal Data. If the Controller objects and the parties cannot resolve the objection, the Controller may suspend or terminate this Agreement with respect to the affected processing.

⚠️ NEEDS LAWYER INPUT — Confirm the 30-day notice period and the objection/termination mechanism are what Applied Neurosciences Pty Ltd actually wants to commit to operationally — this is a real commitment, not boilerplate to leave unexamined.

A shorter notice period is easier to commit to operationally for a small platform; a longer one gives the Controller more real opportunity to act. There is no single correct number here — it is a genuine choice with consequences either way.

6. International Transfers

The Processor is established in Australia, a country the European Commission has not recognised under GDPR Article 45 as providing an adequate level of data protection. Accordingly, the transfer of Personal Data from the Controller to the Processor is governed by the Standard Contractual Clauses (Module Two: Transfer Controller to Processor), attached as Annex IV and incorporated into this Agreement by reference. In the event of any conflict between the body of this Agreement and the Standard Contractual Clauses, the Standard Contractual Clauses shall prevail.

⚠️ NEEDS LAWYER INPUT — Attach the official Module 2 SCC text directly from the European Commission's own published source, not a retyped or paraphrased version.

The current instrument is Commission Implementing Decision (EU) 2021/914 of 4 June 2021, available at eur-lex.europa.eu (search “CELEX:32021D0914”) — confirmed current at the time this draft was built by checking directly, not assumed from memory. For a document with real legal effect, attach the authoritative published text as Annex IV rather than a version retyped into this document, where even a small transcription error could matter. A lawyer should independently re-confirm this is still the current instrument before execution, since this area of law changes.

6.1 Transfer Impact Assessment

Before relying on the Standard Contractual Clauses, Applicable Data Protection Law requires the parties to assess whether the law or practice of the destination country (Australia) undermines the protection the Clauses provide — commonly called a Transfer Impact Assessment (“TIA”). This has not yet been completed and is not a formality; it is a substantive assessment ordinarily requiring legal input.

⚠️ NEEDS LAWYER INPUT — A Transfer Impact Assessment needs to actually be completed before this Agreement is relied on — not just referenced. Suggested scope, for the lawyer conducting it:

Australian government authorities' powers to compel access to data held by an Australian company (e.g. under the Telecommunications and Other Legislation Amendment (Assistance and Access) Act 2018, and any other relevant surveillance/access law) — assessed against the narrow, already-minimal dataset this Processor actually holds (Annex I), which may meaningfully affect the practical risk profile even where the legal powers themselves are broad.

Whether the Privacy Act 1988 (Cth) and the Australian Privacy Principles provide protections that are, in substance, comparable to the safeguards the SCCs are meant to preserve.

Whether any supplementary technical or contractual measures beyond the SCCs themselves and the security measures in Annex II are warranted as a result of this assessment.

7. Data Subject Rights Assistance

The Processor shall promptly notify the Controller if it receives a request directly from a Data Subject seeking to exercise their rights under Applicable Data Protection Law, and shall not respond to that request itself except to acknowledge receipt and direct the Data Subject to the Controller, unless otherwise instructed by the Controller.

A practical point, distinct from the standard obligation above: for the great majority of submissions, the Processor holds no information capable of identifying the Data Subject at all — the Controller alone retains the mapping between a case reference and a patient's identity (Annex I; Developer Specification Section 4.3). As a result, most data subject rights requests (access, erasure, rectification) will in practice need to be fulfilled by the Controller from the Controller's own records, since the Processor typically has nothing identifiable on file to act on by the time such a request could be made — the relevant submission's data will usually already have been purged (Annex II, Clause 3) before any request naming a specific patient could reach the Processor.

8. Security of Processing

The Processor shall implement and maintain the technical and organisational measures described in Annex II, having regard to the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of Data Subjects.

9. Personal Data Breach Notification

The Processor shall notify the Controller without undue delay after becoming aware of a Personal Data breach affecting the Controller's Personal Data, and shall provide the Controller with sufficient information to allow the Controller to meet any obligation to report the breach under Applicable Data Protection Law, including at minimum:

- a description of the nature of the breach, including, where possible, the categories and approximate number of Data Subjects and records concerned;
- the likely consequences of the breach;
- the measures taken or proposed to address the breach, including measures to mitigate its possible adverse effects.

 **NEEDS LAWYER INPUT** — Confirm a specific notification timeframe (e.g. “without undue delay and in any event within 48 hours”) rather than leaving “without undue delay” undefined — a specific number is usually stronger for the Controller and clearer for the Processor to actually operationalise.

10. Liability

⚠️ NEEDS LAWYER INPUT — This entire section is a placeholder — liability allocation, any caps, and indemnification are squarely legal/commercial decisions with real financial consequences, and should be drafted by a lawyer, not inferred from the platform's technical architecture the way most of the rest of this document was.

Points a lawyer will likely want to consider: how liability under this Agreement interacts with the liability terms already in the Terms of Service (currently Section 7, “Limitation of liability” — that section was drafted without a DPA in view and will likely need revisiting alongside this document, not in isolation from it); whether any liability cap is appropriate given Applied Neurosciences Pty Ltd's scale; and how liability is apportioned between the parties where a breach originates with a Sub-processor (Annex III).

11. Term and Termination

This Agreement takes effect on the date the Controller's QEEG.com.au account is created and the Controller accepts the Terms of Service, and remains in effect for as long as that account remains active, or until terminated in accordance with this Clause.

Either party may terminate this Agreement if the other party is in material breach of its obligations under this Agreement or the Standard Contractual Clauses and, where capable of remedy, fails to remedy that breach within 30 days of written notice.

⚠️ NEEDS LAWYER INPUT — Confirm the termination mechanics align with whatever the Terms of Service ultimately say about account closure, and address what happens to any data still in flight (a submission mid-processing) at the moment of termination.

12. Governing Law and Jurisdiction

⚠️ NEEDS LAWYER INPUT — Governing law and jurisdiction for THIS Agreement need a lawyer's decision — not necessarily the same answer as the Terms of Service's, since the SCCs themselves specify particular jurisdiction rules for disputes arising under the Clauses specifically (see Clause 18 of the Module 2 SCC text in Annex IV) that this Agreement must not contradict.

The Module 2 SCCs require disputes under the Clauses to be resolved in the courts of an EU Member State, and (in the version of the Clauses reproduced in Annex IV) name a specific Member State — this needs to be selected and kept consistent with whatever this Agreement states separately for the DPA body itself.

Signature

For and on behalf of the Controller (Data Exporter):

Name: _____

Title: _____

Date: _____

For and on behalf of Applied Neurosciences Pty Ltd (Data Importer):

Name: _____

Title: _____

Date: _____

Annex I — Details of Processing

This Annex describes the processing in the terms the Standard Contractual Clauses require (Annex I.A/B of the Module 2 Clauses). Every fact stated here is drawn directly from the platform's actual, tested architecture (Developer Specification v2.3), not a generic description — a lawyer should still confirm it stays accurate as the platform evolves.

A. List of Parties

	Data Exporter	Data Importer
Name	[Referring practitioner / practice — completed at execution]	Applied Neurosciences Pty Ltd (QEEG.com.au)
Role	Controller	Processor

B. Description of Transfer

Categories of Data Subjects: Patients/clients of the Controller whose QEEG, TOVA, and/or symptom checklist data is submitted to the Services.

Categories of Personal Data transferred: Age (in years) and gender only. No name, date of birth, date of test, or time of test is ever transmitted — stripped in the Controller's own browser before any data leaves their device (Developer Specification Section 4.3). Alongside age and gender, de-identified clinical/technical data is transmitted: QEEG band-power and reliability data, TOVA scores, symptom-checklist responses, handedness, and non-patient-identifying technical fields (e.g. recording equipment, sampling rate).

Sensitive data categories and applied restrictions: See Clause 3's lawyer-review flag regarding whether the above should be treated as GDPR Article 9 special category data.

Frequency of transfer: Continuous, on a per-submission basis at the Controller's initiation — not a bulk or scheduled transfer.

Nature of processing: Automated correlation of the de-identified data described above against a curated literature knowledge base and live academic literature search (PubMed, Semantic Scholar), producing an AI-generated report. No human reviews individual submissions.

Purpose of processing: To generate a literature-correlation report for the Controller's own clinical consideration.

Retention period: Per-submission data (the uploaded files and the generated report) is deleted automatically and permanently the moment the Controller downloads the completed report, or on a backstop schedule if never downloaded — there is no standing retention period. Platform activity logs (metadata only — timestamps and event types, not clinical content) are retained for 5 years.

Annex II — Technical and Organisational Security Measures

Every measure below is drawn from the platform's actual, tested implementation (Developer Specification v2.3 and its companion codebase), not a generic security-measures template.

1. Client-side de-identification

Patient-identifying data (name, date of birth, every date field, and any field found to duplicate a patient-identifying value — see Clause 1.3 below) is stripped in the Controller's own browser before any data is transmitted to the Processor's infrastructure. The Processor's servers never receive this data, at any point — this is a structural property of the client-side code, confirmed by automated testing, not a policy applied after receipt.

2. Encryption

All data in transit is encrypted (HTTPS/TLS). All data at rest is encrypted for as long as it exists on the platform — which, per Clause 3 below, is not long.

3. No standing retention — automatic deletion on download

Unlike a conventional retention policy that deletes data after a fixed period, this platform deletes each submission's data (uploaded files and generated report) the instant the Controller's download completes. Reports never downloaded are purged on a backstop schedule. This has been verified by automated testing against a real database, including that the deletion is an actual row removal, not a status flag.

4. Authentication and access control

Every Controller account requires a bcrypt-hashed password (12-character minimum) and mandatory TOTP-based two-factor authentication (RFC 6238, verified against the official published test vectors) — there is no way to access the Services with a password alone. Login attempts are rate-limited (account-scoped, not just per-session) to prevent brute-force attacks against either the password or the second factor. Lost-authenticator recovery uses single-use backup codes, hashed and never retrievable in plaintext after initial issuance.

5. Case-reference architecture — the Processor structurally cannot re-identify a Data Subject

Each submission is tracked only by an opaque, system-generated case reference. The mapping between a case reference and a specific patient is held only by the Controller, in the Controller's own records — the Processor is never given this mapping and has no mechanism to reconstruct it. Re-identification (stamping the patient's identity onto the downloaded report) happens entirely in the Controller's own browser at download time and is never transmitted to or performed by the Processor.

6. Activity logging

Platform events (uploads, downloads, purges, login attempts) are logged with timestamps for operational and security purposes. Logs record metadata about what happened, not clinical content, and are retained for 5 years independent of the underlying clinical data's much shorter lifecycle.

7. AI-generation safeguards

Reports are generated by an automated system with no human review before delivery; this is disclosed to the Controller on every report. The generation logic is built with specific, tested constraints against producing a diagnosis or treatment recommendation, and against presenting any correlation — including where a disclosed conflict of interest applies (the neurofeedback domain specifically) — without the required disclosure.

 **NEEDS LAWYER INPUT — Confirm whether this Annex needs to name the specific hosting provider (Digital Pacific) and its own security certifications/practices, which have not been independently verified as part of this platform's own testing.**

Annex III — Sub-processors

Sub-processor	Role	Notes / what still needs confirming
Digital Pacific	Infrastructure hosting (Sydney, Australia)	The physical/virtual server the Services run on. Encrypted at rest; see Annex II.
Anthropic	Processes de-identified clinical findings to generate the correlation report	A genuine sub-processor for the purposes of this Agreement — it receives and processes the de-identified data described in Annex I in order to produce the report. Anthropic's own data handling terms, hosting locations, and any further sub-processing chain need to be obtained from Anthropic's own commercial/DPA documentation and reviewed here — not assumed.
PayPal	Payment processing	Processes the Controller's own payment details for the service fee — this is the Controller's own data as a paying customer, not the Data Subject's (patient's) personal data, and may not need to sit in this Annex at all depending on how the lawyer scopes it. Flagged here for completeness rather than pre-judged.
PubMed / Semantic Scholar	Literature search — outbound queries only	These receive search terms derived from de-identified clinical findings (e.g. a symptom/QEEG pattern), not the Data Subject's personal data as such, and arguably are not “sub-processors” under GDPR in the way Anthropic and Digital Pacific are. Confirm this framing rather than accept it as settled — it has not been tested with a lawyer.

⚠️ NEEDS LAWYER INPUT — This list should be cross-checked against the actual, current implementation before this Agreement is executed — sub-processors can change as the platform is built out (e.g. a payment provider substitution, or an email-delivery provider once password-reset

email sending is implemented).

Annex IV — Standard Contractual Clauses

Attach here the official text of the Standard Contractual Clauses, Module Two (Transfer Controller to Processor), as set out in the Annex to Commission Implementing Decision (EU) 2021/914 of 4 June 2021.

Source: eur-lex.europa.eu, search “CELEX:32021D0914”, or https://eur-lex.europa.eu/eli/dec_impl/2021/914/oj — confirmed as the current, correct instrument for this transfer scenario (EEA controller to non-adequate-country processor) at the time this draft was prepared. Deliberately not reproduced or paraphrased within this document itself — attach the Commission's own published text directly, so there is no risk of a transcription error in a document with real legal effect.

⚠ NEEDS LAWYER INPUT — The Module 2 Clauses contain several ‘docking’ and optional provisions the parties must actively choose (e.g. Clause 7’s optional docking clause; the governing Member State law selected under Clause 17; the competent courts selected under Clause 18). None of these selections have been made in this draft — they need a lawyer's decision, not a default.